Audit Scope and Goals

Summary: The internal audit needs to align current business practices with industry standards and best practices. The audit is meant to provide mitigation recommendations for vulnerabilities found that are classified as “high risk,” and present an overall strategy to improve the security posture of the organization. The audit team needs to document their findings, provide remediation plans and efforts, and communicate with stakeholders.

Scope: The internal IT audit will assess the following:

- Assess user permissions
- Identify existing controls, procedures, and system protocols
- Account for technology currently in use

Goals: The goals for the internal IT audit are:

- Adhere to the NIST Cybersecurity Framework (CSF)
- Establish policies and procedures to ensure compliance with regulations
- Fortify system controls

Risk Assessment

Current assets

Assets managed by the IT Department include:

- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Internal network: protected storage of customer, vendor, organizational data

Risk description

Currently, there is inadequate management of assets. Additionally, proper controls are not in place and the organization may not be compliant with U.S. and international compliance regulations and standards.

Control best practices

The organization will need to dedicate resources to managing assets. Additionally, they will need to determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1-10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to necessary compliance regulations and standards.

Additional comments

The likelihood of a lost asset or fines from governing bodies is high because the organization does not have all of the necessary controls in place and is not adhering to required regulations and standards related to keeping PII data private.

Controls Assessment

Administrative Controls			
Control name	**Control type and explanation**	**Needs to be implemented (X)**	**Priority**
Password policies	Preventative; establish password strength rules to improve security/reduce likelihood of account compromise through brute force or dictionary attack techniques	X	High

Technical Controls			
Control Name	**Control type and explanation**	**Needs to be implemented (X)**	**Priority**
Intrusion Detection System (IDS)	Detective; allows IT team to identify possible intrusions (i.e., anomalous traffic) quickly	X	HIgh
Encryption	Deterrent; makes confidential information/data more secure (i.e., website payment transactions)	X	High/ Medium

Physical Controls			
Control Name	**Control type and explanation**	**Needs to be implemented (X)**	**Priority**
Closed-circuit television (CCTV) surveillance	Preventative/detective; can reduce risk of certain events; can be used after event for investigation	X	High/ Medium
Locks	Preventative; physical and digital assets are more secure	X	High

Compliance Checklist

General Data Protection Regulation (GDPR)

GDPR is a European Union (EU) general data regulation that protects the processing of EU citizens' data and their right to privacy in and out of EU territory. Additionally, if a breach occurs and a EU citizen's data is compromised, they must be informed within 72 hours of the incident.

Explanation: The organization needs to adhere to GDPR because we conduct business and collect personal information from people in the EU.

Payment Card Industry Data Security Standard (PCI DSS)

PCI DSS is an international security standard meant to ensure that organizations storing, accepting, processing, and transmitting credit card information do so in a secure environment.

Explanation: The organization needs to adhere to PCI DSS because we store, accept, process, and transmit credit card information in person and online.

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
	●	Least Privilege
	●	Disaster recovery plans
	●	Password policies
	●	Separation of duties
●		Firewall
	●	Intrusion detection system (IDS)
	●	Backups
●		Antivirus software
	●	Manual monitoring, maintenance, and intervention for legacy systems
	●	Encryption

- Password management system
- Locks (offices, storefront, warehouse)
- Closed-circuit television (CCTV) surveillance
- Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Then, select "yes" or "no" to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
		Only authorized users have access to customers' credit card information.
		Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
		Implement data encryption procedures to better secure credit card transaction touchpoints and data.
		Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
		E.U. customers' data is kept private/secured.

- There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
- Ensure data is properly classified and inventoried.
- Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	●	User access policies are established.
	●	Sensitive data (PII/SPII) is confidential/private.
●		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
	●	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): Several security controls need to be implemented to improve BOTIUM TOY's security posture. Such as: disaster recovery plans for business continuity, password policies to protect systems integrity, separation of duties etc. In terms of compliance, they have to implement CIA triad to identify their assets and risks related to them.